Bloque 1: Introducción, Gobernanza y el Ciclo de Desarrollo Seguro

FADENA

Arquitectura Zero Trust y Marcos Corporativos

Ing. Roxana Quiroga Sollinger



DevSecOps

Módulo 2: Arquitectura Zero Trust y Marcos Corporativos

FADENA

2.1 Arquitectura y gobierno Zero Trust

2.2 Microsoft Security Development Lifecycle

2.3 Seguridad en DevSecOps



Módulo 1: Fundamentos de Seguridad en el Software

FADENA

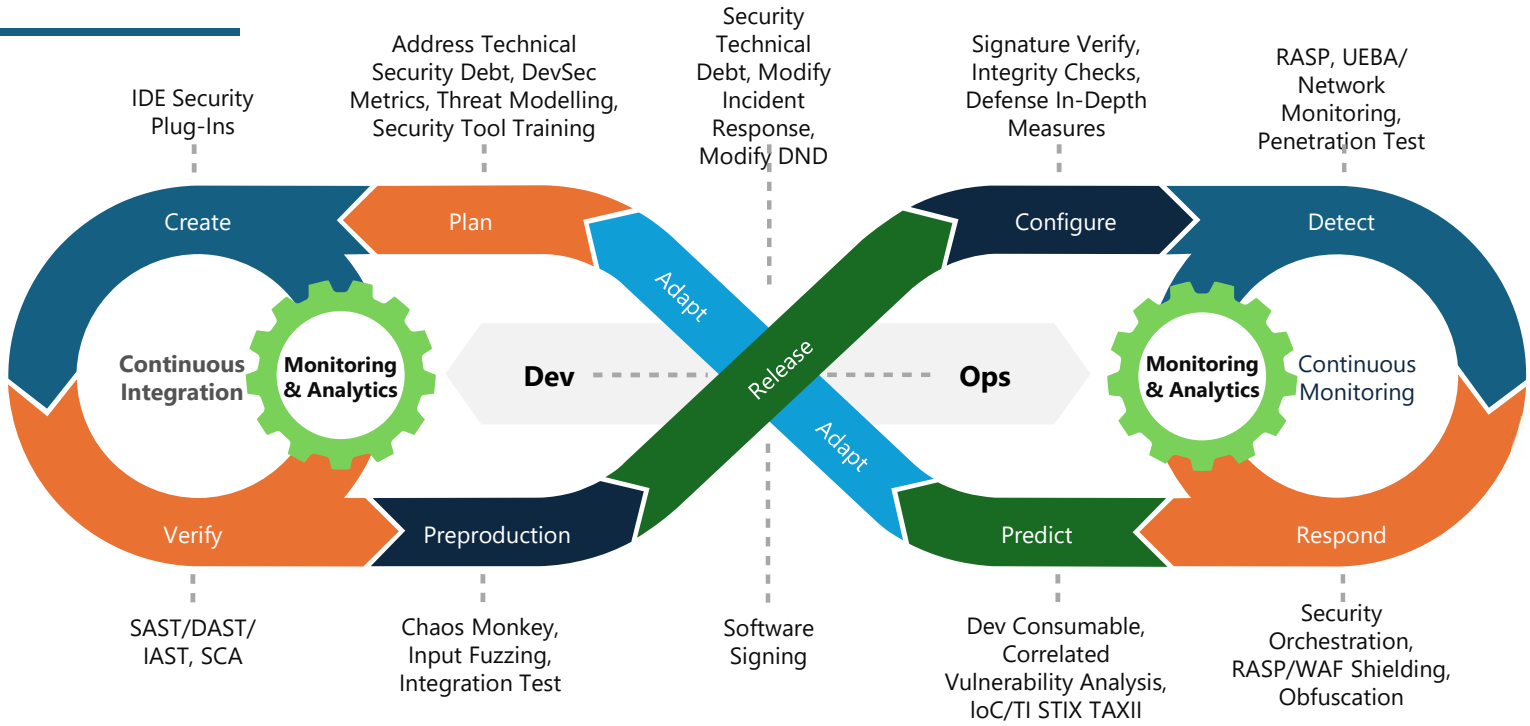
Seguridad en DevSecOps



FADENA

2.3 Seguridad en DevSecOps

Tecnología DevSecOps

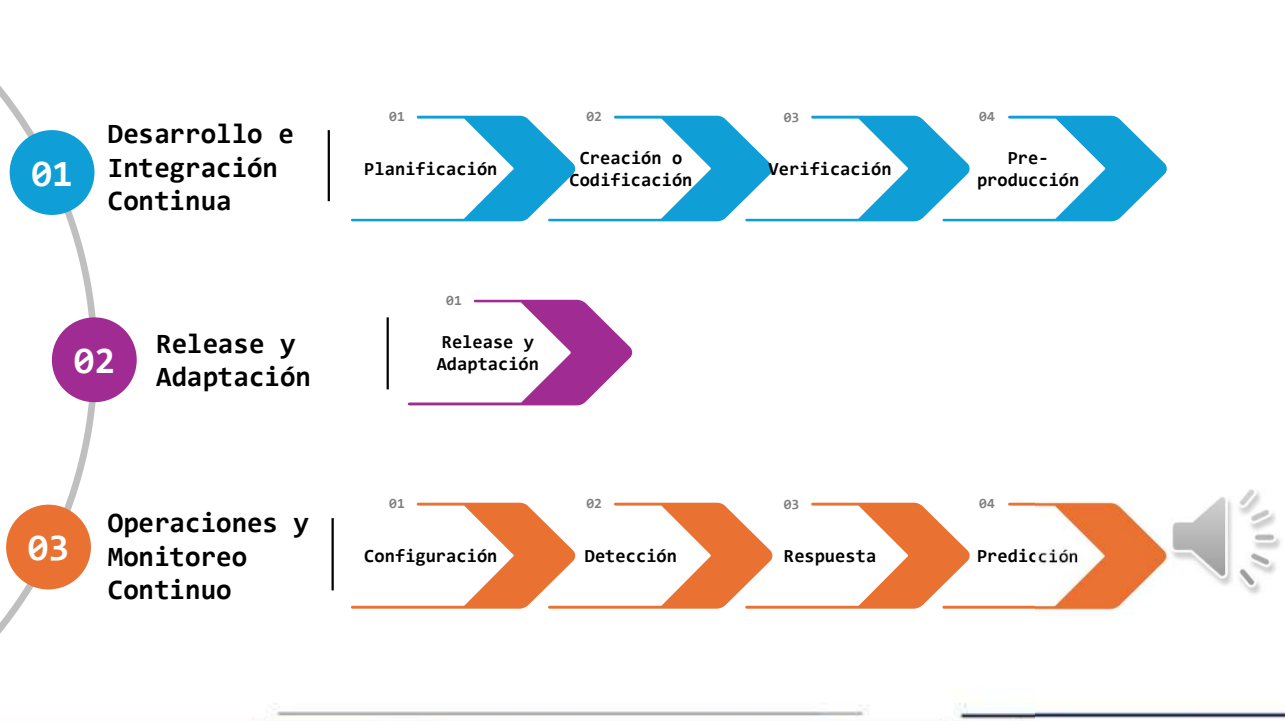


FADENA

2.3 Seguridad en DevSecOps

Tecnología DevSecOps





2.3 Seguridad en DevSecOps

Tecnología DevSecOps

Principios DevSecOps



Colaboración

Implementar herramientas para mejorar la colaboración entre equipos. Promover el flujo de información.

Flujo de valor contínuo

Implementar herramientas de CI/CD que garanticen la Entrega constante y fluida. Automatizar tareas manuals y rutiarias.

Empoderamiento

El empoderamiento de los integrantes del equipo impulsa mejores resultados mediante la autonomía y la gestión directa del ciclo de vida del software.

Aprendizaje continuo y retroalimentación

permiten entender el impacto directo de cada cambio mediante dos pilares: la Entrega de lotes pequeños (CI/CD) y la telemetría y observabilidad integral y compartida mostrando el efecto de cada modificación.

Shift Left

Eleva la calidad del producto y acelera las entregas mediante la integración temprana de validaciones.

2.3 Seguridad en DevSecOps

Tecnología DevSecOps

Desarrollo e Integración Continua

01 Planificación

Establecer los cimientos de seguridad antes de escribir código.

- Modelado de amenazas (Threat Modelling)
- Métricas de DevSec
- Capacitación en herramientas de seguridad.
- Gestión de la deuda técnica de seguridad.

02 Creación o Codificación

Prevenir vulnerabilidades directamente en el entorno de desarrollo.

- Plugins de seguridad integrados en el IDE que analizan el código en tiempo real mientras el desarrollador lo escribe.

03 Verificación

Evaluar el código fuente y sus dependencias de forma automatizada.

- SAST: Pruebas estáticas sobre el código fuente
- DAST: Pruebas dinámicas en la aplicación en ejecución
- IAST: Pruebas interactivas dentro del entorno de ejecución
- SCA: Análisis de componentes de código abierto para identificar dependencias vulnerables

04 Pre-producción

Validar la resistencia de la aplicación en entornos similares a producción.

- Pruebas de integración
- Input Fuzzing (inyección masiva de datos aleatorios para detectar fallos)
- Ingeniería de caos (como Chaos Monkey para simular caídas de sistemas)

2.3 Seguridad en DevSecOps

Tecnología DevSecOps

Release y Adaptación

Release

01

Asegurar el paso de artefactos de desarrollo a producción y retroalimentar el proceso.

- Firma digital de software (Software Signing)
- Actualización de planes de respuesta a incidente
- Resolución de deuda técnica acumulada.

2.3 Seguridad en DevSecOps

Tecnología DevSecOps

Operaciones y Monitoreo Continuo

01 Configuración

Desplegar e infraestructura segura basada en principios de mínima exposición

- Verificación de firmas de software
- Controles de integridad
- Estrategias de defensa en profundidad (Defense In-Depth).

02 Detección

Prevenir vulnerabilidades directamente en el entorno de desarrollo.

- RASP (autoprotección de la aplicación en tiempo de ejecución)
- UEBA (análisis del comportamiento de usuarios y entidades)
- Monitoreo de red
- Pruebas de penetración (Pentesting).

03 Respuesta

Mitigar y reaccionar activamente ante amenazas detectadas.

- Orquestación de seguridad (SOAR)
- Blindaje mediante WAF (Firewall de Aplicaciones Web)
- RASP (Runtime Application Self-Protection), junto con técnicas de ofuscación.

04 Predicción

Anticiparse a futuros vectores de ataque usando información contextualizada.

- Análisis correlacionado de vulnerabilidades
- Consumo de Indicadores de Compromiso
- Intercambio de inteligencia de amenazas mediante estándares.